Incident Report: Persistent Linux Mint Cinnamon 22 Compromise

Target Audience: System Administrator / Clean Media Builder (Dad)

1. Executive Summary

My Linux Mint 22 Cinnamon environment is currently compromised by a highly stealthy, persistent backdoor. The backdoor hides its processes under the name captain. It masquerades as a Python execution environment, establishing local persistence and running inside the graphical user session.
Because the threat actors (suspected to be sophisticated, such as the Gallium/UNC2814 cluster) utilize "living-off-the-land" techniques, standard malware scanners will not catch this. The system is completely untrustworthy.
We need a **full drive wipe and a clean operating system reinstall** using a verified ISO written from a known-clean machine.

2. Forensic Evidence Gathered

Below are the exact outputs and findings analyzed from my active memory and system checks:

A. The Rogue Process (captain)

- **Active PIDs:** 20810 and 26111
- **Process Spoofing:** When checked, these running processes show as captain in ps and pstree.
- **The Reality:** Checking /proc/[PID]/exe reveals the executing binary is actually /usr/bin/python3.12.
- **Quarantine Status:** The original script file /usr/bin/captain has been deleted from the disk, but the malware is **still running directly in system memory** because the active processes were never terminated, or are being dynamically spawned.

B. Process Parentage & Systemd Session Placement

- **Parent Process ID (PPID):** 1 (systemd / orphaned).
- **Process Tree:**
  captain(20810)─┬─{captain}(20811)
  ├─{captain}(20812)
  └─...

- **CGroup Placement:** The process is running inside /user.slice/user-1000.slice/session-c1.scope.
- **Transient Status:** It is nested under the active Cinnamon graphical session wrapper spawned by lightdm. This means the malware is directly integrated into the user interface

startup flow.

C. Where the Backdoor is NOT (Persistence Analysis)

To find out how it keeps coming back, we checked the standard locations and found:

- **Cron Jobs:** None (no crontab for mint, no crontab for root). Standard /etc/cron.* directories are clean.
- **Autostart Directory:** ~/.config/autostart/ is completely empty.
- **Standard Systemd Units:** No active systemd user or system services contain the string captain.
- **Shell Profiles:** Grepping .bashrc, .profile, and .bash_profile returned no matches.

3. The Root Cause: The Grub2Win / Compromised Windows Host Loop

The reason we cannot find any persistence mechanism *inside* the Linux system files is because of how this environment is booted: **It is running as a Live USB/loopback boot via Grub2Win over a compromised Windows host.**
This setup completely breaks the security boundary of a Live USB:

1. **Raw File Access:** Because the Linux loopback file or Live USB partitions are stored on/accessible to the physical drive, the compromised Windows OS has full read/write access to them.
2. **Pre-Boot Modification:** The Windows-based malware can dynamically mount the Linux image, inject the captain Python payload directly into the Live directory structure, modify the grub boot parameters, or patch the ramdisk (initramfs) *before* Linux even boots.
3. **Hypervisor/Host Attacks:** If Windows is infected with a rootkit, it can monitor keystrokes, intercept network traffic, or manipulate system memory at a level that the guest Linux system cannot detect.

4. Addressing the Replit Question

Could this have anything to do with running Replit in a Firefox window?

- **Direct Answer:** No, simply having a Replit tab open in Firefox cannot drop a persistent, system-level Python backdoor on your host machine. Modern browsers run websites in strict, isolated sandboxes.
- **The Real Connection:** The compromise came from the host Windows OS itself. Once Windows was infected, any guest OS running alongside it (including this Grub2Win Linux setup) was immediately and transparently compromised from the outside.

5. Requirements for the New Linux ISO & Reinstall

To ensure the new system is 100% clean and secure, please help me build the new installation media under these strict conditions:

1. **Known-Clean Build Environment:** The ISO must be downloaded, verified, and flashed to a USB drive using a completely different, trusted computer (not this machine).

2. **Cryptographic Verification:** Please run a SHA256 checksum verification on the downloaded Linux Mint ISO against the official Linux Mint release keys before writing it to the USB.
3. **Bare-Metal Nuclear Option (Full Disk Wipe):** During the installation process, we must select the option to **erase the entire physical disk completely**.
    - This means destroying the Windows partitions, the Grub2Win configurations, and the Linux partitions.
    - If we attempt to preserve any partitions or dual-boot with the old Windows host, the malware will immediately re-infect the clean Linux install.
4. **Hardened Post-Install Steps:**
    - Do not copy over any old config files, hidden folders (.config, .local), or browser profiles.
    - Only copy back raw personal data (documents, images, music) after scanning them from a clean, isolated environment.
    - Change all master passwords (email, banking, cloud services) from the newly installed, clean operating system.